

CO2 Assessment Tool 1

NAME : **UDHAYA KUMAR U**

Reg no : **192424332**

Course Code : **ITA-1408 Ethical Hacking**

Q1. Nmap Scan Analysis (20 Marks)

Answer

A security analyst scanned the target **192.168.1.10** using the **Nmap** tool. The scan identified the following open ports:

- Port 22 – SSH (Secure Shell)
- Port 80 – HTTP (Web Server)
- Port 3306 – MySQL Database
- Operating System and Service Versions

Security Risks

1. HTTP (Port 80)

- Data transmitted over HTTP is not encrypted.
- Sensitive information may be intercepted by attackers.
- Vulnerable web applications may allow attacks such as SQL Injection or Cross-Site Scripting (XSS).

2. SSH (Port 22)

- Weak passwords may allow brute-force attacks.
- Outdated SSH versions may contain known vulnerabilities.
- Unauthorized access could compromise the server.

3. MySQL (Port 3306)

- If exposed to the Internet, attackers may attempt unauthorized database access.
- Weak database passwords increase the risk of data theft.
- Misconfigured databases can expose confidential information.

4. Operating System Information

- OS detection helps attackers identify known vulnerabilities.
- Older operating systems may contain unpatched security flaws.

Possible Attacker Exploitation (Defensive Perspective)

- Attempt password guessing or brute-force attacks against SSH.
- Probe web applications for common vulnerabilities such as SQL injection or file upload flaws.
- Target exposed database services if they are improperly configured.
- Research publicly known vulnerabilities affecting the identified operating system or service versions.

Security Recommendations

1. Disable unnecessary open ports.
2. Use **HTTPS** instead of HTTP.
3. Enable **Multi-Factor Authentication (MFA)** for SSH.
4. Use strong passwords and SSH key authentication.
5. Restrict MySQL access to trusted hosts only.
6. Keep operating systems and services updated.
7. Configure firewalls to limit access.
8. Perform regular vulnerability assessments.

Conclusion

The Nmap scan helps identify exposed services and potential security risks. Proper system hardening, regular updates, strong authentication, and secure configurations significantly reduce the risk of compromise.

Q2. GoPhish Campaign Analysis (20 Marks)

Answer

A phishing awareness campaign was conducted using GoPhish for employees of ABC Technologies Pvt. Ltd.

Campaign Results

- **40%** clicked the phishing link.
- **20%** entered their login credentials.
- Several employees downloaded a malicious attachment.

Security Weaknesses

1. Employees Clicked Suspicious Links

- Employees failed to verify the authenticity of the email.
- Indicates low awareness of phishing attacks.

2. Credential Disclosure

- Some employees entered usernames and passwords on a fake website.
- Demonstrates inadequate verification of login pages.

3. Downloading Malicious Attachments

- Employees opened potentially harmful files.
- Could lead to malware infection or ransomware.

User Awareness Programs

- Conduct regular cybersecurity awareness training.
- Organize simulated phishing campaigns.
- Teach employees how to recognize phishing emails.
- Encourage reporting of suspicious emails.
- Provide secure password management training.

Email Security Controls

- Implement **SPF**, **DKIM**, and **DMARC**.
- Deploy advanced email filtering.
- Block executable attachments from unknown senders.
- Scan attachments for malware.
- Enable URL filtering and link protection.

Organizational Policies

- Enforce **Multi-Factor Authentication (MFA)**.
- Implement strong password policies.
- Verify sensitive requests through official communication channels.
- Restrict software installation by users.
- Conduct regular security audits.

Conclusion

The phishing simulation revealed that employees remain vulnerable to social engineering. Continuous training, stronger email security, and well-defined organizational policies can significantly reduce the likelihood of successful phishing attacks.

Q3. DNS Zone Transfer Analysis (10 Marks)

Answer

The Dig assessment showed that the organization's DNS server allows a successful DNS Zone Transfer (AXFR).

Information Exposed

- Internal hostnames
- Mail servers
- DNS records
- Public subdomains
- Name servers

Security Implications

- Reveals the organization's network structure.
- Exposes internal server names.
- Identifies mail servers used by the organization.
- Helps map publicly accessible systems.

How Attackers Could Exploit This Information (Defensive Perspective)

If a DNS server is misconfigured, attackers could use the disclosed DNS records to better understand the organization's infrastructure. This information may make phishing, impersonation, or targeted reconnaissance more convincing and efficient, even without directly compromising systems.

Best Practices to Secure DNS

1. Disable unauthorized DNS Zone Transfers.
2. Allow AXFR only for authorized secondary DNS servers.
3. Enable **DNSSEC**.
4. Restrict recursive DNS queries.
5. Use firewall rules to limit DNS access.
6. Monitor DNS logs regularly.
7. Audit DNS configurations periodically.

Conclusion

DNS Zone Transfers should only be permitted between trusted DNS servers. Proper DNS configuration and monitoring help prevent information leakage and strengthen the organization's overall security posture.